

Aplicación para la Gestión De Pacientes Ingresados en Planta

Anexo IV: Plan de Seguridad

Trabajo de Fin de Grado
Grado en Ingeniería Informática



Julio 2025

Autor

Miguel Barranquero Díez

Tutor/a

Gabriel Villarrubia González

Vivian López Batista

INDICE

1.	INTRODUCCIÓN	3
2.	PUNTOS CRÍTICOS DE SEGURIDAD	4
2.1	CONTROL DE ACCESO Y AUTENTICACIÓN	4
2.1.1	FUNDAMENTO LEGAL	5
2.2	COMUNICACIÓN SEGURA – HTTPS	7
2.2.1	FUNDAMENTO LEGAL	8
2.3	BASE DE DATOS – ALMACENAMIENTO DE CONTRASEÑAS	9
2.3.1	FUNDAMENTO LEGAL	10
2.4	BASE DE DATOS – COPIAS DE SEGURIDAD	11
2.4.1	FUNDAMENTO LEGAL	11
2.5	AUDITORIA DEL SISTEMA Y REGISTRO DE ACTIVIDAD (LOGS)	13
2.5.1	FUNDAMENTO LEGAL	13
2.6	GESTIÓN DE ERRORES	15
2.6.1	FUNDAMENTO LEGAL	15
2.7	PREVENCIÓN DE INYECCIONES	17
2.7.1	FUNDAMENTO LEGAL	17

1. INTRODUCCIÓN

El siguiente anexo tiene como objetivo detallar el Plan de Seguridad aplicado al desarrollo e implementación de la aplicación web de gestión de pacientes.

En este documento se procederá a la identificación de los puntos críticos de seguridad de la aplicación, aquellos elementos cuya vulnerabilidad podría comprometer la confidencialidad, integridad o disponibilidad de la información o los sistemas. Asimismo, se analizarán posibles vectores de ataque y se explicarán las medidas técnicas adoptadas para mitigar o eliminar dichos riesgos, tales como sistemas de autenticación robustos, cifrado de datos, control de acceso y mecanismos de auditoría.

Además, se incluirán consideraciones de tipo legal y normativo, imprescindibles en un entorno sanitario, especialmente en lo relativo a la protección de datos de carácter personal y al cumplimiento de la legislación vigente.

2. PUNTOS CRÍTICOS DE SEGURIDAD

En este apartado se detallan los puntos críticos de seguridad identificados en el desarrollo de la aplicación web de gestión de pacientes hospitalizados. Estos puntos corresponden a componentes del sistema cuya exposición o mal diseño podría representar un riesgo significativo para la seguridad.

Este análisis permite comprender cómo se ha abordado la seguridad desde una perspectiva preventiva

2.1 CONTROL DE ACCESO Y AUTENTICACIÓN

El control de acceso y la autenticación constituyen uno de los pilares fundamentales de la seguridad en cualquier aplicación web. La confidencialidad de la información clínica, la trazabilidad de las acciones realizadas por los usuarios y la prevención de accesos indebidos son requisitos imprescindibles tanto desde un punto de vista técnico como normativo.

En el caso concreto de esta aplicación, desarrollada en Node.js con el framework Express, se ha diseñado un sistema de autenticación y control de acceso adaptado a un entorno multiusuario, en el que coexisten distintos perfiles con permisos diferenciados (como personal médico, administrativo, de secretaría). Es necesario garantizar que cada usuario acceda únicamente a los recursos que le corresponden.

Vulnerabilidades más importantes;

- Acceso no autorizado: si los roles no se validan correctamente, un usuario podría acceder a áreas restringidas.
- Falsificación de identidad: si el token no es seguro o es predecible, podría ser falsificado.
- Falta de caducidad de sesión: sesiones ilimitadas pueden ser explotadas si el dispositivo queda desatendido.

Para gestionar de forma segura la autenticación y el control de acceso se ha implementado un sistema basado en JSON Web Tokens (JWT). JWT es un estándar abierto (RFC 7519) que permite transmitir información entre dos partes de forma segura y compacta mediante objetos JSON firmados digitalmente.

Cuando un usuario inicia sesión correctamente en la plataforma, el servidor genera un token JWT que contiene información clave del usuario: su identificador (ID), su nombre, otros datos del usuario y de forma especialmente importante, su rol dentro del sistema.

Este token tiene una duración limitada de 8 horas, lo que ayuda a mitigar riesgos asociados a sesiones prolongadas o desatendidas. El token es enviado al cliente y almacenado para ser utilizado en futuras solicitudes.

En cada petición posterior a una zona protegida del sistema, el cliente debe incluir el token JWT en la cabecera de la solicitud. En el servidor se intercepta esta solicitud y se realiza un proceso de verificación y descryptado del token. Si el token es válido, se extrae el contenido del mismo y se accede al rol del usuario. Este rol permite determinar dinámicamente qué vistas o funcionalidades debe renderizar el sistema en función de los permisos asociados a dicho rol.

2.1.1 FUNDAMENTO LEGAL

La implementación de esta medida contribuye no solo a proteger la información de los usuarios, sino también a cumplir con lo establecido en el Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo (RGPD), en particular con los artículos relativos al tratamiento seguro de los datos y a la protección de los derechos del interesado desde el diseño del sistema.

- Artículo 25 del RGPD – Protección de datos desde el diseño y por defecto:

“El responsable del tratamiento aplicará [...] las medidas técnicas y organizativas apropiadas, como la seudonimización, concebidas para aplicar de manera efectiva los principios de protección de datos, como la minimización de datos, e integrar las garantías necesarias en el tratamiento para cumplir los requisitos del presente Reglamento y proteger los derechos de los interesados”

El uso de autenticación por contraseña hash, combinado con tokens temporales limitados en información, se alinea con este principio al proteger los datos desde la fase de diseño del sistema, evitando su exposición innecesaria.

- Artículo 5.1.f del RGPD – Integridad y confidencialidad:

“Los datos personales serán tratados de manera que se garantice una seguridad adecuada [...] incluida la protección contra el tratamiento no autorizado o ilícito [...] mediante la aplicación de medidas técnicas u organizativas apropiadas.”

Este artículo exige que los accesos estén controlados, limitados y protegidos, lo que se materializa en la verificación del usuario antes de cualquier operación sensible, evitando accesos no autorizados o accidentales.

- Artículo 32 del RGPD – Seguridad del tratamiento:

“El responsable del tratamiento [...] aplicará medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo [...] que incluya, entre otras cosas, la seudonimización y el cifrado de datos personales, la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento”

Los mecanismos de autenticación implementados son clave para cumplir este artículo, ya que la identificación y autorización previas son el primer paso para garantizar que los datos sean accedidos únicamente por personas autorizadas.

2.2 COMUNICACIÓN SEGURA – HTTPS

En la aplicación web se manejará información sensible de pacientes y usuarios por lo que garantizar la confidencialidad e integridad de los datos durante su transmisión es una prioridad, el uso de protocolos como HTTP pueden exponer al sistema a múltiples amenazas de interceptación y manipulación de datos.

Por este motivo, se ha implementado una capa de comunicación segura basada en HTTPS sobre el servidor Express, utilizando un certificado SSL/TLS autofirmado. Aunque este tipo de certificado no cuenta con la validación de una autoridad certificadora, es suficiente en entornos académicos o de desarrollo, y cumple el objetivo técnico de establecer una conexión cifrada entre el cliente y el servidor.

Algunos de los ataques que podría recibir el sistema si no se implementa un protocolo seguro de comunicación serían:

- Ataque Man-in-the-middle (MitM): Un atacante situado entre el cliente y el servidor puede interceptar el tráfico, accediendo a datos confidenciales como contraseñas, tokens JWT o información clínica.
- Suplantación de contenido: Un atacante podría modificar las respuestas del servidor antes de que lleguen al navegador, inyectando código malicioso o alterando la información visualizada.
- Robo de credenciales: Las credenciales transmitidas en texto plano pueden ser capturadas con herramientas de *sniffing* de red si no se cifra la conexión.

Para mitigar estos riesgos la aplicación ha sido configurada para utilizar HTTPS mediante el módulo nativo https de Node.js combinado con el framework de Express. Se ha configurado de la siguiente manera:

1. Se ha generado un certificado autofirmado mediante OpenSSL, que incluye una clave privada y un certificado público (contexto académico).
2. Se ha cargado el certificado en el servidor Express utilizando `https.createServer(certificado)`.
3. Escucha de conexiones seguras en el puerto HTTPS, garantizando que todo el tráfico de cliente servidor esté cifrado.

Este enfoque garantiza que cualquier dato sensible transmitido (como JWTs, formularios de inicio de sesión o registros médicos) esté cifrado punto a punto, protegiéndolo de interceptaciones externas.

2.2.1 FUNDAMENTO LEGAL

El cifrado de las comunicaciones mediante HTTPS no solo protege la privacidad de los usuarios, sino que constituye una exigencia legal conforme al Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo (RGPD), al ser una medida técnica adecuada para garantizar la seguridad de los datos en tránsito.

- Artículo 5.1.f del RGPD – Integridad y confidencialidad:

“Los datos personales serán tratados de manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas”

El cifrado en tránsito mediante HTTPS cumple directamente con este principio, ya que impide que datos sensibles sean interceptados o alterados durante su transmisión.

- Artículo 32 del RGPD – Seguridad del tratamiento:

“El responsable del tratamiento [...] aplicará medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que incluya, entre otras cosas, [...] el cifrado de datos personales.”

Este artículo menciona explícitamente el cifrado como una medida prioritaria, especialmente cuando se trata de datos personales sensibles como los tratados en contextos sanitarios o educativos. HTTPS proporciona una capa efectiva de cifrado que protege contra amenazas externas durante el intercambio de datos entre usuarios y sistemas.

2.3 BASE DE DATOS – ALMACENAMIENTO DE CONTRASEÑAS

Uno de los puntos críticos de seguridad de cualquier aplicación con usuarios es la gestión segura de las credenciales de acceso, en particular de las contraseñas. Una mala práctica extremadamente peligrosa es almacenarlas contraseñas en texto plano dentro de la base de datos, lo cual expone de forma directa a los usuarios si se produce una filtración o acceso no autorizado a la base de datos.

Dado que sistema gestiona a usuarios con distintos niveles de acceso y que suplantar a uno de ellos podría derivar en el acceso no autorizado a datos clínicos, el almacenamiento seguro de contraseñas no es solo una buena práctica, sino un requisito de seguridad crítico.

Algunos de los ataques que podría recibir el sistema si no se almacena de forma correcta las contraseñas serían:

- Robo de credenciales: Si la base de datos es comprometida y las contraseñas están en texto plano, cualquier atacante puede iniciar sesión con esas credenciales, o reutilizarlas en otros servicios (reutilización de contraseñas).
- Filtraciones masivas: En caso de brechas de seguridad, las contraseñas sin cifrar pueden acabar expuestas en foros, *dark web* o servicios automatizados de cracking.
- Ataques de diccionario o fuerza bruta: Si las contraseñas están cifradas con algoritmos inseguros o sin técnicas de *salting*, pueden ser descubiertas rápidamente usando herramientas automatizadas.

Para mitigar estos riesgos la aplicación implementa el cifrado seguro de contraseñas utilizando la librería `bcrypt`. Este sistema no cifra las contraseñas de forma reversible, sino que utiliza un algoritmo de hash unidireccional con SALT, lo cual hace prácticamente imposible recuperar la contraseña original a partir del hash.

El proceso de implementación es el siguiente:

En el momento del registro del usuario o al actualizar su contraseña, se genera un hash seguro de la contraseña original utilizando `bcrypt.hash()`. Este hash es lo que finalmente se almacena en la base de datos, no la contraseña en sí.

En el momento del inicio de sesión, la contraseña introducida por el usuario se compara contra el hash almacenado utilizando `bcrypt.compare()`, lo cual permite verificar su validez sin conocer la contraseña original.

El hash generado incorpora un "salt" aleatorio (cadena añadida al hash para evitar ataques por diccionario o uso de tablas *rainbow*) y un coste computacional configurable (número de rondas), lo que dificulta los ataques automatizados.

Este enfoque garantiza que, incluso si la base de datos fuera comprometida, los atacantes no podrían obtener fácilmente las contraseñas de los usuarios ni usarlas para acceder a la plataforma.

La implementación de esta medida contribuye no solo a proteger la información de los usuarios, sino también a cumplir con los principios legales de privacidad por diseño y por defecto, al no almacenar nunca información sensible en formato directamente utilizable.

2.3.1 FUNDAMENTO LEGAL

La implementación de esta medida contribuye no solo a proteger la información de los usuarios, sino también a cumplir con lo establecido en el Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo (RGPD), concretamente con los principios de "privacidad desde el diseño" (*privacy by design*) y "privacidad por defecto" (*privacy by default*), recogidos en el Artículo 25 del reglamento.

- Artículo 25 del RGPD – Protección de datos desde el diseño y por defecto:

“El responsable del tratamiento aplicará [...] las medidas técnicas y organizativas apropiadas, como la seudonimización, concebidas para aplicar de manera efectiva los principios de protección de datos, como la minimización de datos, e integrar las garantías necesarias en el tratamiento para cumplir los requisitos del presente Reglamento y proteger los derechos de los interesados”

En este sentido, el uso de algoritmos de hash unidireccional como bcrypt garantiza que dicha información nunca sea registrada ni conservada en un formato directamente utilizable. Esto supone una medida técnica preventiva que minimiza el riesgo de exposición de credenciales, incluso ante una posible brecha de seguridad o acceso no autorizado a la base de datos.

Además, esta práctica está alineada con los principios de:

- Artículo 5.1.f del RGPD – Integridad y confidencialidad:

“Los datos personales serán tratados de manera que se garantice una seguridad adecuada [...] mediante la aplicación de medidas técnicas u organizativas apropiadas.”

- Artículo 5.1.c del RGPD – Minimización de datos:

“Los datos personales serán adecuados, pertinentes y limitados a lo necesario en relación con los fines para los que son tratados”

Al almacenar únicamente el hash y no la contraseña en sí, el sistema respeta el principio de minimización, evitando retener más información de la estrictamente necesaria.

2.4 BASE DE DATOS – COPIAS DE SEGURIDAD

La seguridad de una aplicación no solo depende de la protección activa contra ataques, sino también de la capacidad de recuperación ante incidentes. En sistemas que gestionan información sensible como datos de pacientes hospitalarios, una pérdida de datos puede tener consecuencias graves tanto técnicas como legales.

Por ello, se ha considerado crítico el diseño e implementación de un sistema de copias de seguridad automático, seguro y con redundancia, que garantice la disponibilidad de la información incluso ante fallos técnicos, borrados accidentales o ciberataques como el *ransomware*.

Algunos riesgos asociados a la falta de copias de seguridad

- Pérdida irreversible de datos: En caso de fallo del sistema, corrupción de la base de datos o eliminación accidental.
- Ataques de *ransomware*: Cifrado de la base de datos por parte de un atacante que exige rescate. Sin *backup*, la recuperación es imposible.
- Errores humanos: Modificaciones o eliminaciones no deseadas por parte de usuarios o administradores sin respaldo previo.
- Incumplimiento legal: La normativa obliga a garantizar la disponibilidad y restauración de los datos personales (véase RGPD Art. 32.1.c).

El sistema incorpora una estrategia mixta de respaldo. Se ha utilizado la librería *node-cron* para programar un evento que se ejecuta todos los lunes a las 00:00 generando una copia de seguridad de la base de datos, este archivo se guarda localmente en el equipo del servidor permitiendo una recuperación rápida en caso de emergencia local.

También se ha añadido una funcionalidad accesible al administrador del sistema para realizar copias de seguridad manuales bajo demanda.

Además del almacenamiento local, se ha creado una solución segura de almacenamiento en la nube mediante la API de Google Drive y un agente de autenticación de Google (OAuth2). Esto permite:

- Subida automática del archivo .sql generado cada lunes.
- Acceso seguro y controlado a través de las credenciales del proyecto.
- Disponibilidad remota en caso de pérdida del servidor físico.

Este enfoque garantiza la disponibilidad geográfica y la resiliencia del sistema, alineándose con las buenas prácticas de continuidad de negocio.

2.4.1 FUNDAMENTO LEGAL

La implementación de esta medida contribuye no solo a proteger la información de los usuarios, sino también a cumplir con lo establecido en el Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo (RGPD), en relación con la seguridad del tratamiento y la responsabilidad proactiva del responsable de los datos.

- Artículo 32 del RGPD – Seguridad del tratamiento:

“El responsable del tratamiento y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que incluya, entre otras cosas: [...]

c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico.”

Este artículo establece la obligación legal de contar con mecanismos eficaces de respaldo y recuperación ante cualquier interrupción que pueda afectar la disponibilidad de datos personales.

- Artículo 5.2 del RGPD – Principio de responsabilidad proactiva:

“El responsable del tratamiento será responsable del cumplimiento de lo dispuesto en el apartado 1 y capaz de demostrarlo (responsabilidad proactiva)”

Disponer de copias de seguridad auditables y protegidas permite demostrar ante una auditoría o inspección que existen mecanismos técnicos implementados para preservar los derechos de los interesados, incluso ante una contingencia

2.5 AUDITORIA DEL SISTEMA Y REGISTRO DE ACTIVIDAD (LOGS)

En entornos donde se gestionan datos sensibles (como historiales clínicos o expedientes de pacientes hospitalizado), no basta con proteger el acceso; también es fundamental registrar quién accede a qué, cuándo y con qué finalidad. Esto permite:

- Detectar accesos indebidos o sospechosos.
- Rastrear errores o acciones críticas del sistema.
- Cumplir con normativas que exigen trazabilidad y responsabilidad sobre el tratamiento de los datos.

Por tanto, la ausencia de una política de registro y auditoría representa un riesgo de seguridad y cumplimiento legal.

Algunos de los riesgos asociados a la falta de auditoría podrían ser:

- Accesos indebidos no detectados: Si no se registran, es imposible saber si alguien visualizó información sensible sin permiso.
- Dificultad en la detección de incidentes: Sin logs, no se pueden reconstruir los eventos previos a un fallo o ataque.
- Dificultad en la detección de incidentes: Sin logs, no se pueden reconstruir los eventos previos a un fallo o ataque.
- Incumplimiento legal: En el sector sanitario, la trazabilidad del acceso a datos personales es una obligación explícita.

La aplicación incorpora un sistema básico pero extensible de registros de actividad (logs), que permiten auditar las siguientes acciones clave:

- Inicio de sesión: se registra el usuario que accede, con fecha y hora.
- Cambio de contraseña: se registra quién lo realiza y cuándo.
- Consulta de expedientes clínicos: cuando un usuario accede a la información de un paciente o de un paciente ingresado en planta, se genera un log con su ID, su rol, y el recurso accedido.

Los registros de actividad se almacenan localmente en el equipo del sistema en formato .txt. Antes de ser incluidos en el proceso automatizado de copia de seguridad, estos archivos son cifrados mediante el algoritmo AES-256, garantizando que la información se encuentre protegida tanto en tránsito como en reposo. Posteriormente, se suben a Google Drive a través de la API oficial del servicio, utilizando una conexión HTTPS segura. Esta doble capa de protección asegura que los logs solo puedan ser leídos por quien posea la clave de descifrado, reforzando el principio de confidencialidad y minimizando el riesgo en caso de brechas externas.

2.5.1 FUNDAMENTO LEGAL

El registro de actividad y la auditoría del sistema están directamente relacionados con varias disposiciones del Reglamento General de Protección de Datos (RGPD), así como con normativa específica del sector sanitario.

- Artículo 5.2 del RGPD – Responsabilidad proactiva:

“El responsable del tratamiento será responsable del cumplimiento de lo dispuesto en el apartado 1 y capaz de demostrarlo (responsabilidad proactiva).”

El registro detallado de operaciones en el sistema permite demostrar el cumplimiento efectivo de los principios de seguridad, confidencialidad y tratamiento legítimo, tal como exige este artículo.

- Artículo 32 del RGPD – Seguridad del tratamiento:

“El responsable del tratamiento aplicará medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que incluya, entre otras cosas: [...] un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.”

Los mecanismos de auditoría permiten evaluar continuamente la eficacia de las medidas técnicas aplicadas en el sistema.

- Ley 41/2002 – Básica reguladora de la autonomía del paciente:

“El acceso a la historia clínica debe quedar registrado y justificado. Toda actividad que pueda implicar modificación, visualización o eliminación de información clínica deberá permitir trazabilidad y supervisión por parte del centro sanitario.”

Este artículo obliga legalmente a registrar todos los accesos y operaciones realizadas sobre los datos sanitarios, lo que refuerza la necesidad de contar con una infraestructura de auditoría robusta en entornos clínicos.

2.6 GESTIÓN DE ERRORES

En el contexto de una aplicación que trata con información altamente sensible, como historiales médicos y datos personales de pacientes ingresados, la forma en que se gestionan los errores del sistema puede marcar una diferencia crítica en términos de seguridad y confidencialidad. No se trata únicamente de evitar fallos, sino también de manejar los errores de forma que no se exponga información técnica o interna que pueda ser aprovechada por un atacante.

Un sistema que expone mensajes de error detallados está facilitando indirectamente a un posible atacante el mapeo de la infraestructura interna. Por tanto, una gestión deficiente de errores representa un riesgo claro para la seguridad del sistema.

Riesgos asociados a una gestión inadecuada de errores:

- Exposición de información sensible del servidor: mensajes de error completos pueden revelar estructuras internas, nombres de tablas o rutas críticas.
- Facilitación de ataques dirigidos: al mostrar detalles técnicos, un atacante puede adaptar su estrategia en base al conocimiento revelado por el sistema.
- Falta de trazabilidad de errores: si no se registran adecuadamente los errores, es imposible realizar un diagnóstico *post-mortem* eficaz tras un fallo o ataque.

Para evitar los posibles riesgos producidos por una deficiente gestión de errores se ha incorporado las siguientes técnicas:

- Captura estructurada de errores con try/catch: Todas las operaciones susceptibles de generar errores inesperados (consultas a la base de datos, operaciones críticas, etc.) están envueltas en bloques try/catch lo que permite interceptar la excepción antes de que se propague
- Registro local de errores técnicos: Cuando ocurre un error, se registra la información técnica relevante (mensaje, tipo de error, momento en que ocurrió) en un archivo de log localizado en el equipo del sistema. Este archivo forma parte del sistema general de registros y se incluye en las copias de seguridad automatizadas.
- En lugar de devolver el error técnico completo, el sistema responde al usuario con un mensaje controlado y genérico, evitando que el usuario (o un atacante potencial) reciba información estructural del *backend*.

Este enfoque de gestión de errores permite no solo proteger la infraestructura contra fugas de información involuntarias, sino también facilitar el diagnóstico seguro por parte del equipo técnico

2.6.1 FUNDAMENTO LEGAL

La gestión segura de errores no solo es una buena práctica de desarrollo, sino también una obligación legal dentro del marco normativo europeo y español en protección de datos y seguridad de la información

- Artículo 32 del RGPD – Seguridad del tratamiento:

“El responsable del tratamiento aplicará medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que incluya, entre otros:

- la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;

-un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.”

Una gestión incorrecta de errores puede comprometer la confidencialidad e integridad de los datos personales, por lo que su protección es exigida por ley.

- Artículo 5.1.f del RGPD – Integridad y confidencialidad

“Los datos personales serán tratados de manera que se garantice una seguridad adecuada, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas.”

Los errores no gestionados correctamente pueden ser una vía de exposición de datos personales, lo que supondría un tratamiento no autorizado y por tanto una infracción legal.

- Ley 41/2002 – Básica reguladora de la autonomía del paciente

“Toda actividad que pueda implicar modificación, visualización o eliminación de información clínica deberá permitir trazabilidad y supervisión.”

Si un error afectara al tratamiento de datos médicos (por ejemplo, al mostrar u ocultar información clínica), este deberá estar debidamente registrado, y su análisis debe ser posible para cumplir con la trazabilidad exigida en entornos sanitarios.

2.7 PREVENCIÓN DE INYECCIONES

Uno de los vectores de ataque más antiguos, conocidos y peligrosos en el ámbito de las aplicaciones web es la inyección de código, en especial la inyección SQL. Este tipo de vulnerabilidad se produce cuando los datos introducidos por el usuario no son correctamente validados y se utilizan directamente para construir consultas a la base de datos u otros comandos del sistema. Esto puede permitir al atacante manipular el comportamiento interno de la aplicación, acceder a datos confidenciales, o incluso modificar o destruir registros.

Riesgos asociados a la falta de prevención de inyecciones:

- Acceso no autorizado a información confidencial, incluyendo historiales médicos o datos personales.
- Modificación o eliminación de registros críticos (pacientes ingresados, tratamientos, profesionales).
- Acción persistente del atacante: una vez explotada una inyección, el atacante puede insertar puertas traseras o cuentas ocultas.
- Inyección en otros contextos: como comandos del sistema (*shell*), llamadas a APIs, o incluso plantillas HTML.

Para evitar los posibles riesgos asociados a la falta de prevención de inyecciones se han adoptado las siguientes medidas de protección:

Uso de sentencias parametrizadas a través de la librería mysql2: todas las consultas se realizan usando parámetros definidos lo que significa que las entradas del usuario no se concatenan directamente en la consulta, sino que se sustituyen de forma segura en el tiempo de ejecución.

Evitando valores como “1 OR 1=1” se interprete como parte de la consulta SQL

Validación previa de parámetros recibidos: en puntos sensibles de la lógica, especialmente en endpoints que modifican o eliminan datos, se realiza una validación previa de los parámetros

2.7.1 FUNDAMENTO LEGAL

Las inyecciones suponen una forma de acceso y tratamiento no autorizado de datos personales, lo cual está expresamente prohibido por el Reglamento General de Protección de Datos (RGPD) y se considera una infracción grave tanto en el ámbito legal como técnico.

- Artículo 32 del RGPD – Seguridad del tratamiento

“El responsable del tratamiento y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, incluido, entre otros, la protección contra el tratamiento no autorizado o ilícito de datos personales.”

Una inyección que permite a un atacante consultar, alterar o eliminar datos personales representa un tratamiento ilícito, cuya prevención es una obligación legal directa.

- Artículo 5.1.f del RGPD – Principio de integridad y confidencialidad.

“Los datos personales serán tratados de manera que se garantice una seguridad adecuada, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental.”

Las inyecciones pueden afectar tanto a la integridad de los datos (al permitir su modificación) como a su confidencialidad (al posibilitar el acceso a datos protegidos).